

Set 1 Summary of review process

I reviewed the Set 1 architecture by tracing the main user-data flows from the browser/mobile application through the load balancer, web servers, API/backend, SMS verification service, and MySQL databases. I first applied the CIA Triad to identify where confidentiality, integrity, and availability could be compromised. The clearest confidentiality weaknesses were unencrypted HTTP and insufficient database isolation. Integrity was at risk because the diagram explicitly shows SQL queries without prepared statements and because input validation is not defined. Availability was assessed through the public-facing infrastructure, lack of rate limiting, and absence of monitoring and incident-response controls.

I then applied the Principle of Least Privilege to the API, database, and administrative paths. Each user and service should receive only the permissions required for its role, while administrative functions should require authenticated, authorized access. Secure SDLC principles were applied by recommending parameterized queries, validation, security testing in CI/CD, secure session management, and review of infrastructure configuration before deployment.

These changes strengthen ConnectSphere's data-protection posture by reducing unauthorized disclosure, manipulation, and service disruption. They also support GDPR/CCPA-aligned practices such as protecting personal information, restricting access, and maintaining accountability. The recommended failed-authentication/authorization rate is ethically useful because it provides a measurable signal of possible abuse without requiring unnecessary collection of personal content. Centralized, access-controlled logs and documented incident response make security decisions more transparent, auditable, and repeatable.